COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.1 · Securing Wireless & Mobile

Mestre CyberSec · **Aula 4.1 — Securing Wireless & Mobile** (8:58) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Wireless: site survey (mapa do RF); heat mapping (intensidade do sinal); WPA2/Ent (EAP-TLS+RADIUS cada user autentica) muito maior que PSK. MDM: provisionamento, app push, remote wipe. BYOD (pessoal) vs COPE (corporativo pessoal).

💡 Highlights que a prova CompTIA cobra

- WPA2-Enterprise (802.1X+RADIUS) >> WPA2-PSK (senha compartilhada)
- MDM: gerência central do dispositivo; remote wipe se perdido

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'each user authenticates individually to wireless'=WPA2-Enterprise

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.1 — Securing Wireless & Mobile)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• WPA2-Enterprise (802.1X + RADIUS)

Modo de segurança wireless corporativo que utiliza 802.1X com um servidor de autenticação RADIUS (ou TACACS+), fornecendo credenciais por usuário e por sessão via métodos EAP como EAP-TLS.

⚠ ***Armadilha CompTIA:*** *Trigger: 'each user authenticates individually' or 'unique credentials per user' → answer is WPA2-Enterprise (NOT PSK). Always pairs with 802.1X and a RADIUS server.*

• WPA2-Pessoal (Chave Pré-Compartilhada) (WPA2-PSK)

Modo de segurança wireless que usa uma única senha compartilhada (PSK) para todos os usuários, geralmente indicado para ambientes domésticos ou pequenos escritórios sem servidor de autenticação.

⚠ ***Armadilha CompTIA:*** *Trigger: 'shared password', 'small office', or 'no authentication server' → answer is WPA2-PSK. If the same passphrase is given to everyone, it is NOT Enterprise.*

• EAP-TLS (Segurança da Camada de Transporte)

Método EAP que utiliza certificados digitais X.509 tanto no suplicante (cliente) quanto no servidor de autenticação, fornecendo autenticação mútua em redes 802.1X.

⚠ ***Armadilha CompTIA:*** *Trigger: 'certificate-based wireless authentication' or 'mutual authentication with certificates' → EAP-TLS is the strongest EAP method. Know it requires PKI infrastructure.*

• Vistoria do Local / Levantamento de RF (N/A)

Avaliação física do ambiente wireless utilizando ferramentas para mapear a cobertura de RF, identificar zonas mortas, localizar pontos de acesso e detectar fontes de interferência antes da implantação.

⚠ ***Armadilha CompTIA:*** *Trigger: 'planning wireless deployment' or 'optimal AP placement' → perform a site survey. It is the FIRST step in wireless network design.*

• Mapa de Calor (Mapeamento de RF) (N/A)

Representação visual codificada por cores da intensidade e cobertura do sinal wireless em uma área física, usada para validar o posicionamento de APs e identificar zonas de sinal fraco após a vistoria.

⚠ ***Armadilha CompTIA:*** *Trigger: 'visualize signal strength' or 'verify wireless coverage' → heat map. Different from site survey: survey = plan, heat map = validate/visualize the result.*

• Gerenciamento de Dispositivos Móveis (MDM)
Solução centralizada que aplica políticas de segurança, distribui aplicativos e configurações, e fornece capacidades de controle remoto (bloqueio, limpeza, localização) em dispositivos móveis registrados.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'centrally manage corporate smartphones', 'push policies to devices', or 'remote wipe lost phone' → MDM. Required for corporate-owned and often for BYOD via containerization.*

• BYOD (Traga Seu Próprio Dispositivo)
Modelo de política móvel em que os funcionários utilizam seus dispositivos pessoais para o trabalho, exigindo controles de segurança adicionais como registro no MDM, conteinerização ou políticas de uso aceitável.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'employee uses personal phone for work' → BYOD. Key concern: data ownership/privacy; usually mitigated with containerization or MDM with user consent.*

• COPE (Corporativo, Pessoal Habilitado)
Modelo de política móvel em que a organização possui e controla totalmente o dispositivo, mas permite uso pessoal limitado pelo funcionário, equilibrando segurança e flexibilidade do usuário.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'company owns the device but allows personal use' → COPE. Contrast: BYOD = user owns; COPE = company owns with personal use; Corporate-owned = company owns, work-only.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa de logística está se mudando para um escritório em galpão recém-reformado. Antes de instalar qualquer ponto de acesso sem fio, a equipe de rede percorre todo o local coletando dados sobre fontes de RF existentes, cobertura de sinal vinda de inquilinos vizinhos e obstáculos físicos, como prateleiras metálicas e paredes de concreto, que podem atenuar o sinal. Qual atividade melhor descreve o que a equipe está realizando?

A) Análise de protocolos para decodificar quadros beacon e probe no local

B) Validação da linha de base de firmware dos pontos de acesso atualmente implantados lá

C) Site survey (levantamento de local) para mapear a cobertura de RF e identificar fontes de interferência

D) Análise de vulnerabilidade dos controladores sem fio e pontos de acesso do local

QUESTÃO 2 · CENÁRIO DE EXAME

Os usuários do terceiro andar de um prédio-sede reclamam que o desempenho do Wi-Fi cai perto dos elevadores e nas salas de reunião dos cantos. O administrador deseja produzir uma representação visual, com código de cores, mostrando a intensidade do sinal observada em todas as áreas do andar, para localizar lacunas de cobertura. Qual abordagem o administrador deve usar?

A) Um analisador de protocolos para contar quadros de retransmissão perto dos elevadores

B) Um mapa de calor (heat map) de RF gerado a partir de medições de intensidade de sinal coletadas em todo o andar

C) Um scanner de portas para detectar dispositivos não autorizados conectados à VLAN sem fio

D) Uma consulta SNMP comparando a utilização de CPU entre os pontos de acesso do andar

QUESTÃO 3 · CENÁRIO DE EXAME

Uma empresa protege seu SSID corporativo com WPA2 usando uma única passphrase compartilhada por todos os 45 funcionários. Após a demissão de um funcionário, a equipe de segurança percebe que o ex-funcionário ainda conhece a passphrase, e alterá-la exigiria reconfigurar manualmente todos os laptops e celulares. A diretoria deseja revogação imediata de acesso por usuário e autenticação centralizada. Qual solução melhor atende a esses requisitos?

A) Armazenar uma passphrase mais longa em um compartilhamento de rede acessível aos funcionários

B) Habilitar filtragem por endereço MAC nos APs e bloquear o laptop do ex-funcionário

C) Ocultar o SSID e exigir que cada funcionário se conecte manualmente

D) Implementar autenticação 802.1X com um servidor RADIUS usando credenciais por usuário

QUESTÃO 4 · CENÁRIO DE EXAME

O arquiteto de segurança de um hospital está projetando uma nova WLAN WPA2-Enterprise para os dispositivos da equipe médica. A política de conformidade exige que o processo de autenticação valide, por meio de certificados digitais emitidos pela PKI da organização, tanto a rede para cada dispositivo que se conecta quanto cada dispositivo para a rede. Qual protocolo de autenticação o arquiteto deve selecionar?

A) EAP-TLS

B) EAP-TTLS

C) PEAP com MSCHAPv2

D) WPA2-Personal com uma passphrase aleatória de 64 caracteres

QUESTÃO 5 · CENÁRIO DE EXAME

Uma universidade está implantando autenticação 802.1X em 300 pontos de acesso gerenciados por um controlador central. A equipe precisa de um servidor dedicado que receba as solicitações de autenticação encaminhadas pelos pontos de acesso, valide a identidade de cada usuário contra o diretório da instituição e gere registros de sessão para auditar cada conexão sem fio. Qual tipo de servidor deve ser implantado?

A) Um servidor FTP integrado ao diretório

B) Um servidor DNS com atualizações dinâmicas habilitadas

C) Um servidor RADIUS

D) Um servidor syslog para coletar logs de eventos dos APs

QUESTÃO 6 · CENÁRIO DE EXAME

Uma agência de marketing acabou de comprar 250 smartphones de propriedade da empresa para distribuir à equipe de campo. A TI precisa impor remotamente um bloqueio de tela de seis dígitos, verificar se a criptografia do dispositivo está habilitada, distribuir (push) um aplicativo cliente proprietário da loja corporativa e restringir qual aplicativo é usado para o e-mail corporativo — tudo em escala, sem tocar fisicamente nos dispositivos. Qual solução a TI deve implementar?

A) Um agente de segurança de acesso à nuvem (CASB) para inspecionar o tráfego dos serviços em nuvem

B) Uma plataforma de gerenciamento de dispositivos móveis (MDM) para registrar e configurar os dispositivos

C) Um firewall de nova geração com inspeção SSL no perímetro da rede

D) Um provedor de logon único (SSO) federado com a plataforma de e-mail

QUESTÃO 7 · CENÁRIO DE EXAME

Uma diretora comercial deixa o telefone emitido pela empresa em um táxi durante uma viagem ao exterior e não consegue recuperá-lo. O dispositivo contém e-mail corporativo em cache, listas de contatos de clientes e um perfil de cliente VPN instalado. Qual ação da TI protege mais diretamente os dados confidenciais armazenados no telefone perdido?

A) Desativar a conta dela no diretório para que não consiga logon em outros dispositivos

B) Colocar o IMEI do telefone na lista negra junto à operadora móvel

C) Rotacionar a autoridade certificadora da VPN, mantendo o perfil no dispositivo

D) Enviar um comando de limpeza remota (remote wipe) ao telefone pelo console do MDM

QUESTÃO 8 · CENÁRIO DE EXAME

Uma diretoria decide reforçar o controle móvel e, ao mesmo tempo, melhorar a experiência dos funcionários: a empresa comprará os dispositivos, manterá a propriedade administrativa completa e aplicará baselines de segurança corporativas; ainda assim, os funcionários poderão instalar aplicativos pessoais e usar os dispositivos para fotos e mensagens pessoais fora do horário de trabalho. Qual modelo de implantação corresponde a esses objetivos?

A) BYOD, com a equipe usando dispositivos comprados pessoalmente para o trabalho

B) CYOD, com a equipe escolhendo entre modelos aprovados pela empresa, para uso exclusivo de trabalho

C) COPE

D) Implantação em modo quiosque restringindo cada dispositivo a um único aplicativo corporativo

QUESTÃO 9 · CENÁRIO DE EXAME

Uma consultoria permite que os funcionários acessem o e-mail corporativo e os repositórios de documentos a partir de seus celulares pessoais. Contratos de privacidade proíbem apagar dispositivos pessoais inteiros ou ler dados pessoais, mas os dados corporativos acessados por esses celulares ainda precisam ser protegidos. Qual abordagem melhor satisfaz os dois requisitos?

A) Impor limpeza remota completa do dispositivo de qualquer celular registrado quando seu usuário se desligar

B) Implementar containerização para que apps e dados corporativos executem em um perfil de trabalho isolado e gerenciado

C) Exigir que os funcionários desabilitem o desbloqueio biométrico e o aplicativo de câmera pessoal

D) Mover o e-mail corporativo para um portal web público que exija troca de senha mensal

QUESTÃO 10 · CENÁRIO DE EXAME

Nos horários de pico em uma instalação fabril, os usuários relatam desconexões intermitentes e baixa vazão, embora suas mesas indiquem sinal Wi-Fi cheio. Um técnico descobre que todos os pontos de acesso na banda de 2,4 GHz foram configurados no mesmo canal, por consistência. O que o técnico deve fazer primeiro para resolver o problema de desempenho?

A) Realizar um site survey com análise de espectro e reatribuir os APs entre os canais não sobrepostos 1, 6 e 11

B) Aumentar a potência de transmissão de todos os pontos de acesso para sobrepor sinais concorrentes

C) Implantar pontos de acesso adicionais no mesmo canal para dividir a carga de clientes

D) Desabilitar a divulgação do SSID em todos os APs para reduzir a congestão de quadros beacon

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Site survey (levantamento de local) para mapear a cobertura de RF e identificar fontes de interferência

Trata-se de um site survey sem fio: uma vistoria pré-implantação que documenta o ambiente de RF existente, sinais externos de redes vizinhas, fontes de interferência e fatores físicos de atenuação (paredes, racks metálicos, concreto). Os resultados definem o posicionamento ideal dos APs, a potência de transmissão e os canais. Análise de protocolos decodifica pacotes, mas não mapeia cobertura; validação de firmware verifica o código dos dispositivos, não o ambiente de RF; e a análise de vulnerabilidade avalia a postura de segurança dos equipamentos, não onde o sinal irá se propagar.

Questão 2: Alternativa B — Um mapa de calor (heat map) de RF gerado a partir de medições de intensidade de sinal coletadas em todo o andar

Um mapa de calor é uma representação gráfica com código de cores da intensidade do sinal de RF sobreposta à planta do andar, produzida a partir de medições coletadas durante o site survey. Ele expõe visualmente zonas mortas e áreas de cobertura fraca, como a região próxima aos elevadores (os poços metálicos atenuam fortemente o RF) e as salas dos cantos, apoiando decisões de reposicionamento ou acréscimo de APs. Um analisador de protocolos confirmaria sintomas como retransmissões, mas não mapeia a cobertura visualmente; o scanner de portas e a consulta SNMP de CPU auditam dispositivos e cargas dos APs, sem retratar a propagação do sinal.

Questão 3: Alternativa D — Implementar autenticação 802.1X com um servidor RADIUS usando credenciais por usuário

O WPA2-Enterprise substitui a chave pré-compartilhada pela autenticação 802.1X baseada em porta, contra um servidor RADIUS centralizado. Cada usuário se autentica com credenciais únicas (normalmente vinculadas a um diretório como o Active Directory), de modo que uma única conta pode ser desativada em segundos, sem tocar em qualquer outro dispositivo. Uma passphrase mais longa em um compartilhamento é uma solução autodestrutiva; a filtragem MAC é trivialmente falsificável e não oferece gestão centralizada de identidades; ocultar o SSID não protege a chave e não resolve a revogação, pois a passphrase continua sendo um único segredo compartilhado.

Questão 4: Alternativa A — EAP-TLS

O EAP-TLS é o método EAP baseado em certificados que fornece autenticação mútua: o servidor apresenta um certificado que os clientes validam, e cada cliente também deve apresentar seu próprio certificado emitido pela PKI, atendendo ao requisito bidirecional da política (sendo amplamente considerado o tipo de EAP mais forte). O EAP-TTLS e o PEAP-MSCHAPv2 estabelecem um túnel TLS para validar o certificado do servidor, mas os clientes se autenticam com credenciais tradicionais em vez de certificados de cliente, de modo que a autenticação mútua do dispositivo está ausente. Uma passphrase WPA2-Personal de 64 caracteres continua sendo um segredo compartilhado e não atesta a identidade de um dispositivo individual.

Questão 5: Alternativa C — Um servidor RADIUS

Em uma implantação 802.1X, o ponto de acesso atua como autenticador (os suplicantes são os dispositivos dos usuários), encaminhando as tentativas de autenticação a um servidor RADIUS, que é o backend AAA (autenticação, autorização, contabilização) padrão das redes corporativas sem fio. O RADIUS valida as identidades dos usuários contra um diretório e gera registros de contabilização/sessão para auditoria. Um servidor FTP transfere arquivos, um servidor DNS resolve nomes, e um servidor syslog apenas coleta passivamente logs de eventos; nenhum deles executa autenticação ou contabiliza��ão de sessões.

Questão 6: Alternativa B — Uma plataforma de gerenciamento de dispositivos móveis (MDM) para registrar e configurar os dispositivos

Essas são capacidades centrais do MDM: registro em massa de dispositivos corporativos, imposição remota de configurações de segurança, como complexidade de senha e criptografia, distribuição remota (push) de aplicativos e controles de política no nível de aplicativo — tudo gerenciado centralmente de um console. Um CASB governa o tráfego entre usuários e serviços em nuvem, mas não configura o dispositivo; um NGFW de perímetro inspeciona fluxos de rede e não gerencia endpoints; o SSO simplifica a autenticação nos aplicativos, mas não impõe proteção do dispositivo nem entrega de aplicativos.

Questão 7: Alternativa D — Enviar um comando de limpeza remota (remote wipe) ao telefone pelo console do MDM

O risco imediato são os dados fisicamente presentes no dispositivo perdido. A limpeza remota via MDM apaga o telefone registrado — removendo e-mails em cache, contatos e perfis/certificados provisionados — eliminando diretamente os dados em risco. Desativar a conta dela no diretório afeta apenas sua identidade em outros sistemas, não os dados do telefone; a lista negra de IMEI na operadora impede o uso da rede celular, mas deixa os dados

armazenados intactos; rotacionar a AC pode bloquear conexões VPN futuras, mas também deixa os dados em cache recuperáveis no aparelho.

Questão 8: Alternativa C — COPE

O COPE (corporativo pessoal habilitado — Corporate-Owned, Personally Enabled) é definido exatamente por essa combinação: a organização é dona do hardware e o controla totalmente, aplicando suas baselines de segurança, enquanto os funcionários podem usá-lo pessoalmente, com apps, fotos e mensagens pessoais. No BYOD, o dispositivo pertence ao funcionário, dando à empresa bem menos controle administrativo. No CYOD, os dispositivos também pertencem à empresa, mas a característica definidora é a escolha do modelo pelo funcionário, normalmente sem habilitação para uso pessoal. Uma implantação em modo quiosque trava o dispositivo em uma função corporativa e contradiz o requisito de uso pessoal.

Questão 9: Alternativa B — Implementar containerização para que apps e dados corporativos executem em um perfil de trabalho isolado e gerenciado

A containerização divide um dispositivo BYOD em um contêiner corporativo gerenciado (perfil de trabalho) e uma zona pessoal separada. O e-mail, os documentos e os apps corporativos executam dentro do contêiner sob a política da empresa, e, quando o usuário se desliga, apenas o contêiner é apagado — fotos, mensagens e apps pessoais permanecem intactos — atendendo à proteção e ao acordo de privacidade. A limpeza completa viola explicitamente a proibição de apagar dispositivos pessoais; desabilitar biometria e câmera protege o celular, mas não isola nem protege os dados corporativos; um portal público na verdade amplia a exposição e não oferece imposição de políticas sobre os dados baixados.

Questão 10: Alternativa A — Realizar um site survey com análise de espectro e reatribuir os APs entre os canais não sobrepostos 1, 6 e 11

Barras cheias com vazão ruim é a assinatura da disputa de co-canal: todos os APs no mesmo canal de 2,4 GHz obrigam dispositivos e APs a se revezarem no mesmo tempo de ar. Um site survey com análise de espectro confirma as condições de RF, e a reatribuição dos APs aos três únicos canais não sobrepostos de 2,4 GHz (1, 6 e 11) restaura espectro paralelo utilizável. Elevar a potência aumenta a sobreposição e piora a interferência de co-canal; acrescentar APs no mesmo canal agrava a disputa; SSIDs ocultos continuam emitindo quadros beacon com nome em branco, de modo que ocultar não reduz nada e ignora totalmente o conflito de canais.